CYBERSECURITY SERVICES

Service Catalogue, Delivery Framework & Commercial Terms Checklist

Draft for a private limited company adding cybersecurity services to its web and application development business

Document control	Details
Version	0.2 — working draft for business, technical and legal review
Prepared for	[Company legal name]
Jurisdiction assumption	India; review separately for overseas clients and regulated sectors
Status	Not a signed contract, legal opinion, accreditation, or promise of certification
Review before use	Indian commercial lawyer, CA/tax adviser, company leadership and technical lead

CONFIDENTIAL BUSINESS PLANNING DRAFT

1. Purpose and positioning

This document defines a proposed cybersecurity service line for [Company legal name] (“Provider”). It is designed for small and medium-sized businesses, local professional practices, healthcare clinics, and organisations operating websites, mobile apps, APIs, SaaS platforms and supporting infrastructure.

Positioning: practical, risk-based security testing and secure-development guidance that helps clients find, understand, prioritise and remediate security weaknesses. The Provider should sell a defined assessment and professional report—not a guarantee that a system is completely secure.

2. Service catalogue

Each engagement is individually scoped. Final asset counts, environments, user roles, testing depth, exclusions, schedule, fees and retest terms belong in the Statement of Work (SOW).

Web application security assessment / penetration test

Typical scope: Public or authenticated websites, portals, booking systems, e-commerce, CMS/WordPress and business applications.

Coverage: Authentication, authorisation/access control, session handling, input validation, injection, business logic, file handling, security configuration, sensitive data exposure, client-side security and relevant OWASP WSTG/ASVS coverage.

Deliverable: Scope and coverage statement; executive summary; prioritised findings with evidence, impact, severity, remediation guidance and limitations; optional retest report.

API security assessment

Typical scope: REST, GraphQL, SOAP and other explicitly identified APIs; test and production environments as agreed.

Coverage: Authentication, object/function/property-level authorisation, excessive data exposure, input validation, rate limits, workflow/business logic, token handling, API configuration and relevant OWASP API Security Top 10 risks.

Deliverable: Endpoint/role coverage, findings register, reproduction steps, remediation guidance and agreed retest.

Mobile application security testing

Typical scope: Android and/or iOS apps, associated APIs and agreed test devices/builds.

Coverage: Local storage, cryptography usage, authentication, platform permissions, IPC/deep links, network communication, certificate validation, reverse-engineering resistance where relevant, backend/API authorisation and MASVS/MASTG-informed checks.

Deliverable: Platform/build coverage, findings and evidence, remediation guidance. State clearly whether source review, backend testing and device testing were included.

SaaS / multi-tenant application review

Typical scope: Client-owned SaaS product or tenant, including agreed admin and user roles.

Coverage: Tenant isolation, role separation, account lifecycle, session controls, invitation flows, exports, audit trails, API access, secrets/configuration and tenant-specific business logic.

Deliverable: Role/tenant matrix, findings, impact and recommended fixes. Do not test other customers’ tenants without explicit authority.

AI / LLM application security assessment

Typical scope: Client-owned AI-enabled websites, chatbots, copilots, agentic workflows, LLM-backed APIs, retrieval-augmented generation (RAG) applications, and integrations with approved model providers. Identify the model/provider, application endpoints, user roles, connected tools, data sources and test environment in the SOW.

Coverage may include direct and indirect prompt injection; instruction/data separation; system-prompt or sensitive-context exposure; sensitive-data leakage; insecure output handling; unsafe tool/function calling; excessive agency and

permissions; cross-user or cross-tenant data access; RAG/vector-store access controls; retrieval poisoning risks; authentication/authorisation; rate limits and abuse controls; logging/privacy; model/API key management; insecure integrations; and business-logic abuse.

Deliverable: Defined AI use cases and threat model; tested attack scenarios and assumptions; evidence of validated issues; severity and business impact; mitigation guidance; and a clear list of untested model behaviours, providers, guardrails and dependencies. Distinguish application-layer vulnerabilities from model limitations or expected probabilistic behaviour.

Framework references: OWASP LLM Top 10 (https://owasp.org/www-project-top-10-for-large-language-model-applications/) for application-layer LLM risks; MITRE ATLAS (https://atlas.mitre.org/) for adversarial machine learning TTPs; NIST AI RMF (https://www.nist.gov/system/files/documents/2023/01/26/AI_RMF_1.0.pdf) for AI risk governance. For clients with EU exposure, note relevant EU AI Act obligations. Evidence standards for AI findings: include the exact prompt, model version, temperature or sampling settings, system prompt redacted to agreed level, observed output, and a screen recording or log excerpt where available. Model provider terms of service: before testing an AI application backed by a third-party model provider (OpenAI, Anthropic, Google, etc.), confirm the client has obtained or checked the provider's terms on security testing; some providers require advance notice or have restrictions on adversarial probing of their infrastructure. AI vulnerabilities with cross-user impact should be handled per a responsible disclosure process agreed with the client before testing begins.

AI red teaming / adversarial testing

Typical scope: A separately scoped, time-boxed adversarial exercise against a named AI system, defined user personas, model version, datasets, tools and deployment environment. Test only agreed objectives and approved data.

Coverage may include multi-turn jailbreak attempts, prompt-injection paths through documents/web content, retrieval-boundary bypass, unsafe output and refusal consistency, data-exfiltration attempts, tool-use abuse, guardrail bypass, and robustness against specified adversarial inputs. Define success criteria and expected safe behaviour before testing.

Deliverable: Scenario register, reproducible prompts/conditions where safe, observed versus expected behaviour, risk analysis, mitigations, and regression-test recommendations. Do not claim that a finite test set proves a model is safe or that all jailbreaks have been found.

AI / ML pipeline and model-integration review

Typical scope: Approved review of AI system architecture, model-provider settings, orchestration code, RAG ingestion/retrieval, data flows, model and prompt configuration, fine-tuning or evaluation pipelines, secrets, third-party components and deployment controls.

Coverage may include data minimisation and retention, training/fine-tuning data access, poisoning risks within agreed boundaries, model and package provenance, dependency and plugin risks, tenant isolation, auditability, output validation, human approval for high-impact actions, fallback behaviour, provider-side data-use settings, and separation between untrusted content and privileged instructions.

Deliverable: Architecture/data-flow observations, risk register, prioritised controls and design recommendations. Model extraction, training-data extraction, live-provider abuse, high-volume probing or tests involving personal/sensitive data require explicit written scope and provider/client permission.

Attack surface management and OSINT review

Typical scope: Publicly available information about the named organisation: domains, IP ranges, exposed services, employee data, credential leaks, code repositories and third-party data sources, using only passive and authorised active techniques.

Coverage: Domain and subdomain enumeration, exposed ports and services, certificate transparency, leaked credentials and data in breach databases (checked against known lists only), code and secret exposure in public repositories, employee exposure via social/professional networks, misconfigured cloud storage, and technologies fingerprintable from public responses.

Deliverable: External attack surface inventory, prioritised exposure findings, evidence of discovered assets, remediation guidance, and a note on data sources used. Credential checks use only publicly available breach data and do not attempt live authentication without separate authorisation.

Security awareness training and secure development workshop

Typical scope: Defined audience (developers, general staff, or leadership), session format (workshop, presentation, or online delivery), duration, and whether the content is based on findings from a prior assessment or is general.

Coverage: Tailored to audience: for developers, common vulnerability classes, OWASP Top 10 and secure coding practices; for general staff, phishing and social engineering recognition, password hygiene, incident reporting, and data-handling obligations; for leadership, cyber-risk concepts and governance. Content tied to real findings from a prior assessment where the SOW includes this.

Deliverable: Session delivery, materials (slides and reference guides), attendance record, and a follow-up Q&A summary. Do not describe a general awareness session as a formal certification or compliance attestation. Post-session phishing simulations require a separate SOW and explicit written consent from the client's leadership and HR.

Thick-client / desktop application assessment

Typical scope: Windows, macOS or Linux desktop client plus named backend services.

Coverage: Local data storage, IPC, update mechanisms, authentication, local privilege boundaries, secrets, TLS, input handling and backend/API access controls.

Deliverable: Client/build and platform coverage, findings and remediation recommendations.

Network vulnerability assessment

Typical scope: Named public IPs, internal subnets, hosts and permitted services.

Coverage: Asset/service discovery, exposed ports, service configuration, known vulnerabilities, insecure protocols, segmentation evidence and manual validation of material findings.

Deliverable: In-scope asset list, methodology, validated findings, exposure context and remediation plan. Scan-only work must be labelled vulnerability assessment, not full penetration testing.

Internal network penetration test

Typical scope: Authorised internal network segments, representative endpoints and defined attack paths.

Coverage: Segmentation, privilege boundaries, service exposure, credential-related paths and controlled lateral-movement validation within agreed boundaries.

Deliverable: Attack-path narrative, validated findings, affected systems, risk and containment/remediation guidance. Domain-wide or destructive actions require explicit written approval.

Active Directory / identity security assessment

Typical scope: Named AD domain(s), Entra ID tenant or other identity environment, with agreed access level.

Coverage: Identity configuration, privileged groups, delegation, authentication policies, service accounts, trust relationships, excessive permissions, logging and attack paths appropriate to scope.

Deliverable: Identity-risk findings, prioritised remediation and evidence. Credential dumping, persistence, password spraying and disruptive techniques require explicit rules and may be excluded.

Wi-Fi security assessment

Typical scope: Named SSIDs, access points, locations and authorised test windows.

Coverage: Encryption/security modes, guest/corporate separation, rogue AP exposure checks where authorised, client isolation and authentication configuration.

Deliverable: Coverage and location limitations, findings and recommendations. Deauthentication, disruption or testing against neighbouring networks is prohibited unless expressly authorised and lawful.

Cloud security configuration review

Typical scope: Client-owned AWS, Microsoft Azure, Google Cloud or other named accounts/subscriptions/projects.

Coverage: IAM and privilege, public exposure, storage permissions, network rules, logging, key/secret handling, encryption settings, workload/container configuration and security posture.

Deliverable: Configuration findings, evidence, risk and remediation plan. Read-only access preferred; changes require separate approval.

Firewall / WAF / network-device configuration review

Typical scope: Named firewalls, WAFs, routers, switches, VPN gateways, load balancers and rulesets.

Coverage: Management-plane exposure, admin access, rule hygiene, overly broad rules, segmentation, logging, firmware/support status, secure management protocols, VPN settings, WAF policy and change control.

Deliverable: Configuration review report with risky rules/settings and recommended changes. Active exploitation or configuration changes are not included unless separately approved.

Secure code review / SAST

Typical scope: Named repositories, branches, commit range, languages and build configuration.

Coverage: Manual review and static analysis for input handling, access control, secrets, unsafe APIs, error handling, cryptography use and security-relevant logic.

Deliverable: Findings tied to file/line or component where feasible, confidence, impact and fix guidance. Automated results are triaged to reduce false positives.

SCA / open-source dependency review

Typical scope: Named manifests, lockfiles, SBOMs, container images or repositories.

Coverage: Known vulnerable dependencies, dependency freshness, risky/unmaintained packages, licence concerns if included, transitive dependencies and upgrade paths.

Deliverable: Dependency inventory where supported, relevant advisories, exploitability/context caveats and upgrade recommendations. A vulnerable version does not automatically mean exploitable in the client's environment.

DAST / automated application testing

Typical scope: Named application URLs and test accounts within agreed rate and time limits.

Coverage: Automated discovery and checks for common web weaknesses, supported by manual validation of material findings.

Deliverable: Tool coverage, validated findings and limitations. DAST alone is not a comprehensive penetration test.

Threat modelling during design/development

Typical scope: Architecture diagrams, data flows, assets, trust boundaries, roles, dependencies and deployment model.

Coverage: Identify assets, entry points, trust boundaries, threat actors, abuse cases and threats using a suitable approach such as STRIDE; prioritise mitigations before implementation.

Deliverable: Threat model/workshop notes, threat register, assumptions, design recommendations and action owners. This is a design review, not a guarantee of secure implementation.

Secure architecture and configuration review

Typical scope: Design documents, cloud/network diagrams, deployment pipelines, auth flows and configuration samples.

Coverage: Security controls, trust boundaries, secrets, identity, encryption, logging, environment separation, backup/recovery, dependency and deployment risks.

Deliverable: Prioritised design/configuration recommendations and decisions requiring client acceptance.

Remediation support and retesting

Typical scope: Previously reported findings and agreed changed assets/builds.

Coverage: Developer consultation, fix validation, regression checks limited to agreed areas, and status updates.

Deliverable: Per-finding status: fixed, partially fixed, not fixed, unable to verify, or no longer applicable; residual risk and retest limitations.

3. Assessment modes and access levels

Mode	Meaning	Commercial/technical note
Black-box	Tester starts with limited or no internal knowledge/credentials, within an agreed external scope.	Useful for an external-attacker perspective; may not cover authenticated or internal risks unless included.
Grey-box	Tester receives limited documentation, accounts or role access.	Often effective for web/API testing; define roles, permissions and account lifecycle.
White-box	Tester receives source code, architecture, configuration or broad technical knowledge.	Can provide deeper coverage but requires secure handling of source and secrets.
Authenticated	Testing with one or more authorised user roles.	List each role and test account; test access control across roles only as authorised.
Unauthenticated/ external	Testing from an unauthenticated or external viewpoint.	Specify internet-facing assets, source IPs, timing and hosting-provider rules.

These are assessment approaches, not separate certifications. The SOW must specify the chosen approach; a single engagement may combine modes.

4. Tools and technology

Tools are selected per scope and licence. Tools support professional analysis; they do not by themselves establish that an assessment is complete or that a vulnerability is exploitable. Use only authorised accounts, licences and test targets.

Area	Illustrative tools
Web/API testing	Burp Suite (Community/Professional as licensed), OWASP ZAP, browser developer tools, curl, Postman/Insomnia, suitable API schema tools.
Network discovery and validation	Nmap; approved vulnerability scanners such as Nessus or equivalent where licensed; OpenSSL and curl for protocol/TLS checks.
Web content and exposure discovery	Nuclei templates after review and safe configuration; directory/content discovery tools where appropriate; DNS utilities.
Code and dependency review	Semgrep or equivalent SAST, language-native linters, OWASP Dependency-Check, OSV-Scanner or equivalent SCA, secret scanners and SBOM tools.
Mobile testing	Android Studio/ADB, MobSF where appropriate, platform tooling, Burp/ZAP for permitted traffic analysis, and test devices/emulators.
Cloud and containers	Provider-native security posture tools, cloud CLI with read-only permissions, ScoutSuite/Prowler or equivalents where suitable, Trivy or equivalent container/image scanning.
AD / identity	BloodHound/SharpHound for AD graph enumeration; impacket suite (secretsdump, GetNPUsers, GetUserSPNs, psexec); Responder for LLMNR/NBT-NS/mDNS poisoning; Kerbrute for user enumeration; Metasploit Framework for validated exploitation (authorised engagements only — no persistence, no lateral movement beyond agreed objectives, no destructive actions without explicit written approval); CrackMapExec/NetExec for domain enumeration; Rubeus for Kerberos attacks where in scope. Avoid credential extraction or disruptive techniques unless expressly approved in the Rules of Engagement.
Wireless and network configuration	Approved wireless analysis tools and vendor configuration exports; use controlled test hardware and a defined test location/window.
AI / LLM testing	Garak (LLM vulnerability scanner, https://github.com/NVIDIA/garak); PromptBench and custom adversarial prompt sets; Burp Suite / ZAP for API layer; log analysis via provider-native tools; custom scripts for prompt injection, boundary bypass and tool-call abuse. Never send client data, credentials or sensitive prompts to public AI evaluation or red-teaming platforms without explicit client approval and a confirmed data-processing agreement with the platform provider.
Reporting and evidence	A controlled report template, encrypted storage, access control, version control, a finding tracker and secure file transfer.

The company should maintain a tool register recording owner, licence, approved purpose, update process, data sent to third-party services, and restrictions. Do not upload client source code, logs, credentials or evidence to public AI or SaaS tools unless the client has explicitly approved the service and data handling.

5. Standard delivery methodology

Enquiry and qualification

Understand business objective, asset owner, sector, regulatory/procurement requirements, urgency, environment and expected outcome. Decline work if authority or capability is unclear.

Pre-engagement capability and conflict check

Before issuing a proposal, confirm: (1) the team has direct experience with the requested assessment type — decline or partner if not; (2) no conflict of interest exists between the Provider and the client; (3) required tools, licences, and test-environment access are available for the engagement window; (4) the engagement does not require regulatory approvals, certifications, or empanelment the Provider does not hold. Document this check for every engagement.

Scoping and risk review

Inventory assets, environments, roles, dependencies, third-party services, exclusions, permitted test types, data sensitivity and potential operational impact.

Default engagement exclusions

The following are excluded from every engagement unless explicitly scoped in a separate SOW addendum with client sign-off:

- Denial-of-service and distributed denial-of-service (DoS/DDoS) attacks or load/stress testing of any kind. Availability and resilience testing require a separately negotiated scope, dedicated test window, explicit client approval, and confirmation that upstream providers and hosting services permit it. If load testing is required, the client should raise it as a separate SOW item.
- Destructive actions: deleting, modifying, encrypting or corrupting production data, configurations, or backups.
- Testing of systems or IP ranges not named in the SOW, including assets discovered incidentally during the engagement.
- Exfiltration or retention of real production data beyond what is strictly necessary to evidence a finding — use synthetic data wherever possible, and delete evidence per the agreed retention schedule.

Proposal and contract

Issue quote, MSA or engagement terms, SOW, NDA/data terms as required, written authorisation and Rules of Engagement. Obtain signatures before testing.

Kick-off and readiness

Confirm points of contact, test window, source IPs, accounts, backups, monitoring, incident contacts, emergency stop process and hosting-provider requirements.

Reconnaissance and mapping

Map the approved attack surface and functionality. Record actual coverage and any assets discovered outside scope without probing them further.

Testing and validation

Combine manual testing and suitable automated tools. Validate material findings safely, minimise data access, avoid persistence/destructive actions and follow the Rules of Engagement.

Evidence handling and preservation

Capture a screenshot or request/response log immediately on discovering each material finding. Hash (SHA-256) all evidence packages before transmission. Store evidence in an encrypted folder accessible only to team members on that engagement. Do not store raw evidence in personal cloud storage or unencrypted email. For findings that could become legal matters (active compromise, confirmed data exposure): treat evidence as a potential exhibit — do not modify or re-run the affected system without documenting each action with a timestamp; maintain chain-of-custody

records from discovery to report delivery. Delete all client evidence after the agreed retention period and record the deletion.

Triage and escalation

Notify the designated contact promptly for critical risks, suspected active compromise, accidental exposure or service impact. Pause testing when required.

Analysis and reporting

Review evidence, eliminate false positives, assign justified severity, explain business impact, include remediation guidance and disclose coverage limitations.

Readout and remediation

Explain findings to technical and business stakeholders. Agree remediation owners and priorities; implementation is client-owned unless separately contracted.

Retest and closure

Retest only the agreed findings/assets/builds, record outcomes and residual risks, deliver final report, securely return/delete data according to contract, and close access.

Quality assurance and peer review

Before each report is delivered, a second reviewer (separate from the lead tester) should verify: finding descriptions are accurate and evidence is present; severity ratings are justified and consistently applied; remediation guidance is actionable; coverage and limitation statements reflect what was actually done; no secrets, unnecessary personal data or out-of-scope system data appear in screenshots or evidence. Document the reviewer's name and date in the report. For smaller engagements where a separate reviewer is not available, a structured self-review checklist should be used and retained as a quality record.

Secure client communications

Reports and evidence packages must be transmitted via an encrypted channel: password-protected PDF or ZIP with the password communicated separately, a client-specific encrypted file-sharing link, or a mutually agreed secure portal. Do not send reports, credentials or evidence as unencrypted email attachments. Agree the transmission method at kick-off and document it in the SOW or Rules of Engagement.

Active compromise and critical finding response

If testing reveals evidence of an active compromise, an existing backdoor, or a critical vulnerability presenting imminent risk of harm: (1) stop testing on affected systems immediately; (2) notify the designated client emergency contact within one hour by phone or agreed out-of-band channel; (3) document all observations and preserve evidence without altering the affected system; (4) record the notification time, contact name and response received; (5) do not resume testing until the client provides written authorisation. Note: CERT-In Directions 2022 require organisations to report certain incident categories within six hours of becoming aware. Advise the client of this obligation and confirm whether it applies to findings discovered during the assessment.

Service level commitments

Delivery timelines are defined in the SOW. Recommended defaults by scope: Small engagement (single application, up to 5 days testing): draft report within 5 business days of testing completion. Standard engagement (multi-component, 6–10 days testing): draft report within 10 business days. Large or complex engagement (multi-asset, more than 10 days testing): draft report within 15 business days. Critical findings identified during testing are communicated verbally or by secure message within one business day of validation, ahead of the final report. Retest reports are delivered within 5 business days of retest completion, unless otherwise agreed. All timelines assume the client provides agreed access, accounts and responses to clarification questions promptly. Delays caused by client-side factors extend the timeline by the corresponding period.

6. Report standard and severity

Standard deliverables should be selected in the SOW. A typical report contains:

- Cover page, client/entity, assessment dates, report version, classification and named author/reviewer.
- Executive summary in plain language: purpose, scope, overall risk themes and business implications.
- Scope and exclusions: exact domains/IPs/apps/environments/roles, test mode, dates, and assets not tested.
- Methodology and tools: relevant versions/configuration at a useful level, manual work performed, and standards/guidance used.
- Coverage and limitations: functions/roles/endpoints assessed, inaccessible areas, time constraints and dependencies.
- Finding register: unique ID, title, severity, affected asset, description, preconditions, impact, evidence, reproduction steps, remediation, references and status.
- Risk rating: CVSS version/vector where appropriate, supplemented by business context and exploitability; do not use a score without rationale.
- Positive observations and prioritised remediation roadmap where included.
- Retest appendix: finding-by-finding status and what was actually verified.
- Handling instructions and distribution list; avoid putting secrets or unnecessary personal data in screenshots.

Severity labels may use Critical/High/Medium/Low/Informational, but the scoring model and escalation thresholds must be agreed. A report should not claim “all vulnerabilities found”; use “findings identified within the agreed scope and testing window.”

CVSS floor thresholds: Critical ≥ 9.0; High 7.0–8.9; Medium 4.0–6.9; Low 0.1–3.9; Informational 0.0. These are starting points; business context, exploitability in the client's environment, data sensitivity and presence of compensating controls must adjust the final severity. Always state the CVSS version (3.1 or 4.0) and vector string alongside the score.

Remediation tracking: where agreed, deliver findings in a structured format (CSV, JSON or JIRA-compatible export) alongside the PDF report, so the client can import findings directly into their ticketing or project management system. This does not replace the narrative report but reduces manual transcription errors.

Posture context: where industry benchmarks or maturity frameworks are relevant (for example, OWASP ASVS levels, CIS Controls implementation groups, or sector-specific baseline), include a brief statement of the assessed posture relative to the applicable level. This is indicative context based on the assessment scope, not a formal certification or audit.

Report classification: every deliverable must carry a classification marking agreed at kick-off. Recommended scheme: CONFIDENTIAL — CLIENT ONLY (default; not to be shared outside the named client organisation without written permission); CONFIDENTIAL — NAMED RECIPIENTS (executive summaries with a defined distribution list); RESTRICTED — DRAFT (pre-delivery working versions). Do not mark a report PUBLIC or UNRESTRICTED without explicit client approval.

Report amendment process: after formal delivery, any factual correction requires a new version with an incremented version number and a change-log entry, signed off by the original author and reviewer. Notify all recipients of the superseded version. Confirm whether the correction affects severity ratings, finding count, or retest scope. Minor editorial corrections (typos, formatting) may be issued as errata rather than a full version increment, at the Provider's discretion.

7. Retesting, remediation and awareness

- Quote retesting explicitly: number of rounds (for example, one included round), eligible findings, eligible assets/builds, expiry window, and price for additional rounds.
- Retest results must distinguish fixed, partially fixed, not fixed, unable to verify and not applicable.
- A retest is not a new full penetration test unless the SOW says so. Major code changes, new assets or new features may require a new scope and fee.
- Remediation support can include developer Q&A, secure coding advice, configuration guidance and a workshop; implementation/change activity is separate unless explicitly included.
- Awareness sessions can explain the findings, secure development practices and remediation priorities. Do not describe a general awareness session as a formal certification.

8. Client-facing terms and conditions checklist

These are drafting points for counsel, not ready-to-sign legal clauses. The signed MSA/SOW and authorisation should take precedence over marketing copy.

For AI/LLM engagements, identify the exact application, model/provider and version where known, environment, accounts, connected tools, data sources, user roles, allowed test prompts, rate limits, prohibited content/actions, data sensitivity, provider terms and any required third-party permission.

Specify whether client data, prompts, completions, uploaded documents, logs or embeddings may be sent to any external model/provider or testing service. Prefer synthetic/test data; prohibit uploading secrets or personal/sensitive data unless expressly authorised and approved safeguards are in place.

Define whether testing may attempt prompt injection, jailbreaks, retrieval-boundary bypass, tool/function invocation or adversarial content ingestion; prohibit real-world transactions, destructive actions, uncontrolled mass generation, persistence and testing against third-party models/accounts unless explicitly authorised.

State that AI behaviour is probabilistic and provider-dependent; results may vary by model version, system prompt, temperature, retrieval corpus, guardrails and configuration. The assessment is a time-bounded sample, not a guarantee of safety, regulatory compliance or absence of jailbreaks.

Agree evidence redaction, prompt/output handling, retention/deletion, provider-side logging, confidentiality, incident escalation and whether the client must preserve model/version/configuration details for reproducibility.

Clause	What it should address
Parties and authority	Correct legal names, registered addresses, authorised signatories, client asset-owner authority, approved subcontractors and named contacts.
Scope and change control	Exact assets, environments, dates, test mode, included activities, exclusions and a written change-order process. No verbal scope expansion.
Authorisation and Rules of Engagement	No testing before signed permission and agreed RoE; permitted source IPs, test windows, methods, rate limits, exploitation boundaries and stop conditions.
Client responsibilities	Provide accurate scope, lawful authority, test accounts, backups, contacts, environment details and timely approvals; identify third-party/cloud-hosted assets.
Safety and availability	No DoS/DDoS, flooding, destructive testing, persistence, data alteration, social engineering, phishing, physical testing or production changes unless separately and explicitly authorised.
Data and evidence	Minimum necessary access; secure storage/transfer; restricted staff access; redaction; retention period; return/deletion; incident notification; approved subprocessors and data locations.
Deliverables and acceptance	Report format, delivery date assumptions, debrief, objective acceptance process, correction of factual errors and treatment of disputed findings.
Retesting	Number of rounds, deadline, included findings, test scope, retest output, and price for additional work or changed assets.
Fees and payment	Currency, taxes, advance/milestones, invoice dates, due dates, late payment, cancellation, travel/third-party expenses and extra-scope rates.
Confidentiality	Confidential information, permitted use/disclosure, exceptions, legal disclosure, survival and secure destruction.
IP and licence	Pre-existing tools and methods; client ownership or licence for deliverables; right to reuse generic know-how; no unauthorised publicity or client logo use.
Warranties and limitations	Professional standard of care, no guarantee of zero vulnerabilities/security or future breach prevention, scope/time limitations and explicit exclusions.
Liability and indemnities	Reasonable and negotiated liability cap, excluded/uncapped categories if appropriate, responsibility for each party's acts, insurance and third-party claims; reviewed by Indian counsel.
Incident and escalation	Critical finding process, suspected active compromise, accidental exposure, service disruption, emergency contact, stop-test authority and decision log.
Term and termination	Suspension/termination rights, payment for work performed, safe stop, revocation of access, return/deletion, open findings and surviving obligations.
Law and disputes	Governing law, venue/jurisdiction, escalation process and arbitration only if appropriately drafted and agreed.
DPDP Act 2023 and data protection	India's Digital Personal Data Protection Act 2023 applies to personal data accessed during testing. Minimise personal data access; do not retain personal data beyond the engagement; agree a lawful basis and data-processing addendum where required; confirm data residency and transfer obligations for overseas clients. For health, financial or children's data, apply enhanced controls as appropriate to the category.
CERT-In incident reporting obligations	CERT-In Directions 2022 require reportable incidents to be notified to CERT-In within six hours of becoming aware. Where testing discovers an active compromise or a critical vulnerability that constitutes a reportable incident, advise the client of their notification obligation. Define in the SOW whether the Provider has any reporting obligation as a service provider, and who is responsible for notifying CERT-In.

CERT-In empanelment status	[CERT-In empanelment status: the Provider is not currently empanelled as an Information Security Auditing Organisation under CERT-In. Where a client's procurement, regulatory, or sector requirement mandates an empanelled auditor, the Provider will disclose this limitation in the proposal and, where appropriate, refer the client to or partner with an empanelled firm. Update this clause once empanelment status changes.]
GST, taxes and invoicing	All fees are exclusive of Goods and Services Tax (GST) unless stated otherwise. GST will be charged at the applicable rate on the date of supply. For overseas clients, confirm export-of-services status and FEMA/RBI compliance with a CA before contracting. Provide GST-compliant tax invoices within the statutory period. Withholding tax deductions by the client should be agreed in writing before contract execution.
Professional indemnity and insurance	The Provider must maintain professional indemnity (PI) insurance of at least ₹50 lakh throughout the engagement and for a run-off period of not less than two years after delivery. Proof of current PI cover must be provided to the client on request. Sub-contractors who access client systems or data must maintain equivalent PI cover or be covered under the Provider's policy. Cyber liability insurance is recommended in addition to PI.
Conflict of interest	The Provider must disclose any actual or potential conflict of interest before accepting an engagement, including where the Provider has previously worked for a direct competitor of the client, where a tester has a personal relationship with client staff, or where the Provider has a financial interest in a product or tool being assessed. The client may waive a disclosed conflict in writing or request a different tester. Undisclosed conflicts that emerge during the engagement must be disclosed immediately.
Tester background and vetting	All testers and sub-contractors who access client systems, data or premises should have undergone appropriate background verification, including identity verification and, for engagements involving sensitive data or regulated sectors, a criminal record check. The Provider must maintain records of tester vetting and make them available to the client on request. Testers must not have undisclosed access to client systems outside the agreed engagement scope.
Liability cap	The Provider's aggregate liability to the client for any claim arising out of or in connection with the engagement, whether in contract, tort (including negligence) or otherwise, is limited to the total fees paid by the client for the specific SOW giving rise to the claim. This cap does not apply to: (a) death or personal injury caused by negligence; (b) fraud or fraudulent misrepresentation; or (c) any other category that cannot be limited by law. Have Indian counsel review the cap structure and uncapped categories.
Cancellation and suspension	Either party may suspend or terminate the engagement on 5 business days' written notice. On cancellation by the client after testing has commenced, the client pays for all work completed to the date of notice plus reasonable committed costs. On cancellation by the Provider, the Provider returns prepaid fees for work not yet performed and delivers a partial report covering completed work. Both parties must return or delete all confidential information within 30 calendar days of termination.
Force majeure	Neither party is liable for delays or failures caused by circumstances beyond its reasonable control, including natural disasters, government actions, telecommunications or infrastructure outages, or declared public health emergencies, provided the affected party notifies the other promptly and takes reasonable steps to mitigate the impact. Force majeure does not excuse payment for work already completed.
Sector-specific compliance	Where the client operates in a regulated sector (financial services — RBI/SEBI; insurance — IRDAI; healthcare — ABDM/NHM; payment cards — PCI DSS; listed entities — SEBI), confirm the applicable cybersecurity framework and whether the engagement output is required to satisfy a regulatory audit or assessment. Adjust scope, methodology, tester qualifications, report format and evidence retention accordingly, and obtain specific legal advice on compliance obligations before delivery.
Custom exploit and offensive tool IP ownership	Any exploit, PoC script, custom Nuclei template, payload, or offensive tool created specifically for this engagement is the Provider's intellectual property unless the SOW explicitly transfers ownership. The Provider may reuse and publish engagement tooling that does not identify the client or contain client data. The client may request a copy as a deliverable, subject to a separate written agreement on responsible use and indemnity for misuse. Pre-existing tools are unaffected by this clause.
Entire agreement	The signed MSA/SOW, written authorisation, Rules of Engagement, and any applicable NDA or data-processing addendum constitute the entire agreement for the engagement and supersede all prior discussions, proposals, emails, and marketing material. No pre-execution statement creates an obligation unless incorporated into a signed document. Amendments require written agreement signed by authorised representatives of both parties.
Assignment	Neither party may assign, transfer, or sub-contract rights or obligations without prior written consent of the other, except that the Provider may sub-contract delivery to vetted individuals under its direction, subject to the sub-contractor vetting and PI insurance requirements in these terms. Any purported assignment without consent is void. This clause survives any change of control of either party.
Testimonials, case studies and portfolio references	The Provider may reference engagement type, industry sector, and general outcomes in proposals or marketing material without identifying the client, provided no confidential information or client brand is disclosed. The Provider requires the client's prior written consent to name the client, reproduce its logo, or describe details that could identify the client. The client may request removal of any anonymised reference within 30 days of engagement closure.

No regulatory misrepresentation	No statement of CERT-In empanelment, ISO certification, compliance attestation or third-party approval unless the relevant status and scope are genuinely valid.

9. Document pack to prepare

Document	Purpose / owner
Service catalogue and capability matrix	Sales; state which services are currently deliverable vs planned.
Proposal / quotation template	Commercial lead; scope assumptions, fees, dates, exclusions and validity.
Master Services Agreement (MSA) or service terms	Lawyer; repeat commercial/legal terms.
Statement of Work (SOW) / work order	Commercial + technical lead; exact engagement details.
Written authorisation to test	Client asset owner; explicit permission for identified systems and activities.
Rules of Engagement (RoE)	Technical lead + client; test windows, allowed techniques, safety and escalation.
NDA / confidentiality terms	Lawyer; protect information before and during work.
Data processing/security addendum	Lawyer/privacy adviser; use where applicable to data access/processing.
Subcontractor/services agreement	Company + technical provider; payment, scope, IP, confidentiality, liability, non-solicit if appropriate.
Client intake and scope register	Delivery team; assets, ownership, third-party/cloud dependencies and exclusions.
Pre-test readiness checklist	Delivery team; accounts, backups, contacts, allowlists and stop conditions.
Finding tracker and report template	Technical lead; consistent quality, severity, evidence and remediation.
Critical finding / incident escalation SOP	Technical lead; notification, stop-work and evidence handling.
Retest and closure record	Technical lead; validation status and secure closure.
Professional indemnity insurance certificate	Provider (and sub-contractors); current certificate showing insured name, cover amount (₹50 lakh minimum), policy period and issuer. Renewed annually and provided to clients on request.
Conflict of interest register	Commercial lead; log of disclosed and assessed conflicts for each engagement, client waiver where applicable, and outcome. Retained for the engagement period plus two years.
QA and peer review checklist	Technical lead; completed and signed by the reviewer before each report delivery. Confirms finding accuracy, evidence completeness, severity consistency, coverage accuracy and absence of sensitive data in screenshots.
Tester vetting and background check records	Operations; identity verification and background check outcomes for each tester accessing client systems. Retained securely with restricted access.
Sector regulatory compliance checklist	Commercial + technical lead; mapping of the engagement to applicable sector framework (RBI, SEBI, IRDAI, PCI DSS, ABDM) where relevant. Confirms whether the scope, methodology and report format satisfy the regulatory requirement or whether additional steps are needed.
Tool/licence and data handling register	Operations; licence compliance, updates, approved data flows and access control.

10. Founder / subcontractor operating agreement

- Identify the contracting entity, who signs the client contract, who invoices, and who is responsible for client communications.
- Define the technical provider's role and whether the arrangement is employment, subcontracting, referral, or another legally appropriate model.
- Set a fee model: fixed delivery fee or a defined percentage of collected revenue, with clear treatment of tax, discounts, refunds, costs, late payments and scope changes.
- No discounts, guarantees, deadlines, certification claims or scope commitments that bind the technical provider without prior agreement.
- Technical findings and severity must not be altered for commercial reasons; factual review and dispute resolution are permitted and documented.
- Define ownership/licensing of pre-existing tools, generic templates, report deliverables, jointly developed IP and any client-specific code.
- Define confidentiality, client data access, approved storage, subcontracting, access revocation and deletion at termination.
- Allocate liability according to each party's control and acts; do not accept blanket personal liability for the whole company.

- Define client relationship and non-solicitation terms narrowly and reasonably, with legal review; do not assume broad restraints are enforceable.
- Require all sub-contractors and third-party testers to undergo identity verification and, for engagements involving personal data or regulated sectors, a criminal record check before accessing client systems. Maintain vetting records and make them available to clients on request. Ensure sub-contractors are covered by PI insurance of at least ₹50 lakh or are included under the Provider's own policy.
- Set termination notice, ongoing project handover, payment for completed work, report delivery, unresolved findings and data deletion.

11. Legal and industry references for review

These sources inform the proposed process. They do not replace legal review or mean that the Provider is accredited.

- **CERT-In — Comprehensive Cyber Security Audit Policy Guidelines (25 July 2025) —** Official guidance on audit delivery and applicability; determine whether the client requires an empanelled auditor. https://www.cert-in.org.in/s2cMainServlet?pageid=GUIDLNVIEW02&refcode=CISG-2025-02
- **CERT-In — Empanelment of Information Security Auditing Organisations —** Official status and process information. https://www.cert-in.org.in/s2cMainServlet?pageid=CERTEMPANEL
- **CERT-In — Directions under section 70B —** Official cybersecurity incident directions and related FAQs; check current applicability. https://www.cert-in.org.in/Directions70B.jsp
- **CERT-In — Advisory on improving cyber security audit outcomes —** Emphasises clear scope, broad coverage, comprehensive methods and follow-up remediation. https://www.cert-in.org.in/s2cMainServlet?VLCODE=CIAD-2021-0045&pageid=PUBVLNOTES02
- **OWASP Web Security Testing Guide —** Web application testing methodology reference. https://owasp.org/www-project-web-security-testing-guide/
- **OWASP API Security Project —** API risk reference. https://owasp.org/www-project-api-security/
- **OWASP MASVS / MASTG —** Mobile application security verification and testing guidance. https://mas.owasp.org/
- **NIST SP 800-115 —** Technical guide to security testing and assessment planning. https://csrc.nist.gov/pubs/sp/800/115/final
- **PCI Security Standards Council — Penetration Testing Guidance —** Relevant where a client handles payment-card data; check the current PCI DSS requirements and the client's exact obligation. https://www.pcisecuritystandards.org/
- Information Technology Act, 2000 (India) and IT (Amendment) Act, 2008 — Sections 43 and 66 provide the primary legal basis for authorised computer access testing in India. Written authorisation from the asset/data owner is essential before any testing begins. Sections 43/66 create offences for unauthorised access, data theft, and service disruption. Confirm every engagement has documented written authorisation and consider an authorisation / safe-harbour letter reviewed by Indian legal counsel, especially for internal network and exploitation work. https://www.meity.gov.in/content/information-technology-act
- OWASP Top 10 for Large Language Model Applications — Application-layer LLM risk taxonomy, used as a primary reference for AI/LLM assessment coverage. https://owasp.org/www-project-top-10-for-large-language-model-applications/
- MITRE ATLAS (Adversarial Threat Landscape for AI Systems) — TTP framework for adversarial ML attacks on AI systems. https://atlas.mitre.org/
- NIST AI Risk Management Framework (AI RMF 1.0) — Governance and risk management guidance for AI systems; relevant for clients seeking AI risk posture alignment. https://www.nist.gov/system/files/documents/2023/01/26/AI_RMF_1.0.pdf
- EU AI Act — European Union regulation on AI systems; relevant for clients with EU market exposure or EU-based users. Review applicability with legal counsel where the client's AI system may be in scope. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689
- India Digital Personal Data Protection Act, 2023 (DPDP Act) — Indian data protection law governing personal data processing; applicable to test data handling and to client systems processing personal data. Review with Indian counsel before engaging with personal data. https://www.meity.gov.in/writereaddata/files/Digital%20Personal%20Data%20Protection%20Act%202023.pdf

- RBI Master Direction on Information Technology Framework / Cybersecurity Framework for Banks — Applicable to scheduled commercial banks, payment system operators and RBI-regulated entities. Check the current applicable direction on RBI's official website: https://www.rbi.org.in/
- SEBI Circular on Cyber Security and Cyber Resilience Framework — Applicable to SEBI-registered intermediaries, stock exchanges and depositories. Check the current circular on SEBI's official website: https://www.sebi.gov.in/
- IRDAI Guidelines on Information and Cyber Security for Insurers — Applicable to insurance companies and insurance intermediaries regulated by IRDAI. Check current guidelines on IRDAI's official website: https://irdai.gov.in/

12. Sector-specific regulatory considerations

The following notes are indicative only. They do not constitute legal or regulatory advice. Verify current obligations with Indian legal counsel and the relevant regulator before contracting or delivering services to clients in regulated sectors.

Financial services — RBI-regulated entities

Scheduled commercial banks, urban cooperative banks, payment system operators, non-banking financial companies and other RBI-regulated entities are subject to the RBI Master Directions on Information Technology and Cybersecurity, and related circulars. These typically require: periodic cybersecurity assessments; IS audit by empanelled auditors for certain entity categories; specific vulnerability assessment and penetration testing frequency; incident reporting timelines to RBI (often shorter than general CERT-In timelines); and data-localisation compliance for payment data. Confirm current requirements with RBI guidelines and the client's compliance team before scoping.

Securities markets — SEBI-regulated intermediaries

Stock brokers, depository participants, asset management companies, stock exchanges and other SEBI-regulated market intermediaries must comply with SEBI's Cyber Security and Cyber Resilience Framework (CSCRF). Requirements include a cybersecurity policy, periodic VAPT, BCP/DR testing, security operations monitoring, and incident reporting to SEBI. Engage only empanelled or otherwise approved service providers where SEBI requires it; check the current SEBI circular for applicability to the client's registration category.

Insurance — IRDAI-regulated entities

Insurance companies and insurance intermediaries regulated by IRDAI are subject to IRDAI's Guidelines on Information and Cyber Security. Requirements typically include periodic IT security audits, VAPT, data localisation, and incident reporting. Confirm whether IRDAI requires the auditor to hold specific qualifications or empanelment, and verify the current guidelines with the client's compliance officer.

Healthcare — digital health systems

Organisations participating in the Ayushman Bharat Digital Mission (ABDM) or handling electronic health records should follow ABDM data privacy and security guidelines. Health data is a sensitive personal data category under the DPDP Act 2023. Additional obligations under the National Health Data Management Policy and any sector-specific directions should be verified with legal counsel. Plan for enhanced data-minimisation, consent and breach-notification requirements in the SOW.

Payment card data — PCI DSS

Clients that store, process or transmit cardholder data are subject to PCI DSS. Penetration testing requirements under PCI DSS include defined scope (cardholder data environment), methodology (network and application layer), annual frequency, and use of a qualified tester. Confirm whether the client requires a Qualified Security Assessor (QSA) or an Approved Scanning Vendor (ASV) and whether a Report on Compliance (RoC) or Self-Assessment Questionnaire (SAQ) is required. The Provider must not claim PCI DSS QSA or ASV status unless formally approved by the PCI Security Standards Council.

13. Commercial reference framework

Internal business planning reference only. All figures are indicative ranges based on a lean, India-based delivery model (2026 rates). Actual fees depend on scope, complexity, and duration. Issue fee proposals only in a signed quotation or SOW, not from this document. All fees exclude GST. Minimum engagement value: ₹30,000.

Indicative pricing reference

Service	Indicative range (INR, excl. GST)	Scope assumption
Web application pentest (small, up to 3 days)	₹35,000 – ₹65,000	Single app, up to 5-10 key workflows
Web application pentest (standard, 3-5 days)	₹65,000 – ₹1,20,000	Multi-role, complex auth, API integration
API security assessment	₹30,000 – ₹75,000	Per API surface; often combined with web
Mobile app testing (single platform)	₹50,000 – ₹1,00,000	Android or iOS; includes backend API
Mobile app testing (both platforms)	₹80,000 – ₹1,60,000	Android + iOS, shared backend API
AI / LLM application assessment	₹60,000 – ₹1,50,000	Scope-dependent; agentic systems at higher end
Attack surface management / OSINT	₹25,000 – ₹50,000	Passive + authorised active recon
Network vulnerability assessment (up to /24)	₹25,000 – ₹50,000	External or internal; larger ranges by quote
Internal network penetration test	₹80,000 – ₹2,50,000	Duration and access-level dependent
AD / identity security assessment	₹75,000 – ₹2,00,000	Single domain; multi-domain by quote
Wi-Fi security assessment	₹30,000 – ₹60,000	Per site; multi-site by quote
Cloud security configuration review	₹40,000 – ₹1,00,000	Single cloud provider account
Secure code review / SAST (single service)	₹35,000 – ₹80,000	LOC- and language-dependent
Threat modelling + secure architecture review	₹40,000 – ₹90,000	Workshop-based; complex systems higher
Security awareness training (per session)	₹15,000 – ₹40,000	In-person or online; custom content higher
Retest (one included round)	Included in base engagement fee	
Additional retest round	₹15,000 – ₹30,000 per round	Scope-dependent

Service capability matrix

Active = deliverable now. Active - building depth = deliverable but limit to 1-2 concurrent engagements while methodology depth grows. Subcontractor = partner needed for specialist hardware or skill.

Service	Status	Primary framework	Subcontractor needed
Web application pentest	Active	OWASP WSTG / ASVS	No
API security assessment	Active	OWASP API Top 10	No
Mobile app (Android/iOS)	Active	OWASP MASVS/MASTG	No
SaaS / multi-tenant review	Active	OWASP + custom	No
AI / LLM assessment	Active - building depth	OWASP LLM Top 10,	No

Service	Status	Primary framework	Subcontractor needed
		MITRE ATLAS	
AI red teaming	Active - building depth	MITRE ATLAS, NIST AI RMF	No
AI/ML pipeline review	Active - building depth	NIST AI RMF	No
Attack surface / OSINT	Active	OSINT Framework + custom	No
Security awareness training	Active	OWASP / custom	No
Thick-client / desktop app	Active	OWASP + custom	No
Network vulnerability assessment	Active	NIST SP 800-115	No
Internal network pentest	Active	NIST SP 800-115, MITRE ATT&CK	No
AD / identity security	Active	MITRE ATT&CK / custom	No
Wi-Fi security assessment	Active	IEEE 802.11 / custom	Possibly (hardware)
Cloud security config review	Active	CIS Benchmarks / provider	No
Firewall / WAF config review	Active	Custom	No
Secure code review / SAST	Active	OWASP / CWE	No
SCA / OSS dependency review	Active	CVE / EPSS / OWASP	No
DAST	Active	OWASP WSTG	No
Threat modelling	Active	STRIDE / PASTA	No
Secure architecture review	Active	Custom	No
Remediation support	Active	Engagement-specific	No

Service packages and bundles

Bundles combine commonly requested services at reduced combined scoping overhead. Each bundle needs its own SOW. All figures exclude GST.

- Starter Web — Web application pentest + API security. Typical use: SaaS or e-commerce with REST/GraphQL API. Indicative: ₹75,000 – ₹1,60,000.
- Mobile Stack — Mobile app (Android + iOS) + API security. Typical use: consumer or B2B app with shared backend. Indicative: ₹1,00,000 – ₹2,20,000.
- Full Application — Web + API + Mobile (one platform). Typical use: full product coverage before major release. Indicative: ₹1,20,000 – ₹2,80,000.
- AI Security Starter — AI/LLM assessment + OSINT review. Typical use: product launching an AI feature or chatbot. Indicative: ₹80,000 – ₹2,00,000.
- Infrastructure Essentials — Network VA + Internal network pentest + AD/identity. Typical use: post-merger, new office, or annual compliance. Indicative: ₹1,50,000 – ₹4,50,000.
- Code and Build Quality — Secure code review + SCA + DAST. Typical use: pre-launch gate or compliance requirement. Indicative: ₹80,000 – ₹2,00,000.
- Design Review — Threat modelling + Secure architecture review. Typical use: new product or major feature in design phase. Indicative: ₹70,000 – ₹1,60,000.

Disclaimer

This document is a business and technical planning draft. It is not legal, tax, regulatory, employment or insurance advice, and it is not a ready-to-sign contract. It does not certify the Provider or guarantee compliance. Indian counsel and relevant advisers should adapt the terms to the actual company structure, engagement, sector, data flows, applicable law and client requirements. No security testing should begin without documented authority, an agreed scope and appropriate Rules of Engagement.